

LAB 05

MediCloud - IT Risk Assessment

Zorluk: Orta • Tahmini süre: 30-60 dakika • Rolünüz: Technology Risk Analyst

1. HİKÂYE

Sektör Sağlık teknolojileri	Ölçek 560 çalışan, 74 hastane müşterisi
BT ortamı Azure, Kubernetes, legacy görüntüleme sistemi	Veri Hasta kimliği, klinik kayıtlar ve görüntüler

MediCloud hastanelere bulut tabanlı hasta takip ve görüntüleme hizmeti verir. Yeni yatırım turu öncesi yönetim, kurumsal IT risk değerlendirmesinin yenilenmesini istemiştir. Mevcut risk kayıt defterindeki risklerin çoğu üç yıl önce oluşturulmuştur. Son altı ayda bir fidye yazılımı girişimi engellenmiş, iki müşteri yanlış yapılandırılmış depolama alanı hakkında soru sormuş ve legacy görüntüleme sisteminin üretici desteği sona ermiştir.

2. SİZE VERİLEN GÖREV

Riskleri tek tek teknik zafiyet listesine dönüştürmeden; senaryo, varlık, tehdit, mevcut kontrol, olasılık ve iş etkisi ilişkisiyle güncel bir risk görünümü oluşturun.

3. OLAYLAR VE KANITLAR

E-01 | Risk kayıt defteri
R-12 Ransomware: düşük; R-18 Bulut erişimi: orta; R-24 Eski sistem: düşük. Son review 08.02.2024. Risk sahibi olarak eski CTO görünmektedir.

E-02 | Ransomware olayı
EDR zararlı dosyayı engellemiştir. 23 uç cihaz 11 saat boyunca yönetim konsolunda çevrimdışı görünmüştür. Olay ekibi veri şifrelenmediğini bildirmiştir; olay sonrası tabletop yapılmamıştır.

E-03 | Ayrıcalıklı erişim
Azure'da 17 Global Administrator vardır. Dördü dış destek personelidir. MFA tümünde aktiftir. Üç aylık access review son iki dönemde tamamlanmıştır; dört kullanıcı otomatik onaylanmıştır.

E-04 | Bulut yapılandırması
CSPM raporu 3 kritik, 19 yüksek bulgu gösterir. Kritiklerden biri anonim depolama erişimidir; ekip bunun sentetik test verisi içerdiğini söyler. Veri sınıflandırma kaydı sunulmamıştır.

LAB 05

MediCloud - IT Risk Assessment

Zorluk: Orta • Tahmini süre: 30-60 dakika • Rolünüz: Technology Risk Analyst

3. OLAYLAR VE KANITLAR - DEVAM

E-05 | Yedekleme

Veri tabanı yedekleri iki bölgede saklanır. Son restore testi 15 ay önce başarıyla tamamlanmıştır. Görüntüleme arşivinin restore testi hiç yapılmamıştır; kapasite nedeniyle planlanmaktadır.

E-06 | Üçüncü taraf

Çağrı merkezi hasta randevu verisine erişir. Sözleşmede gizlilik ve olay bildirimi vardır. Son güvenlik değerlendirmesi iki yıl öncedir; şirket geçen yıl altyapı sağlayıcısını değiştirmiştir.

E-07 | Legacy sistem

Üretici desteği bitmiştir. Sistem ayrı ağ segmentindedir ve internet erişimi yoktur. Hastanelerle entegrasyon için iki sabit port açıktır. Değiştirme projesi 18 ay sürecektir.

4. ÖĞRENCİNİN GÖREVLERİ

1. Kritik varlıkları ve risk senaryolarını tanımlayın.
2. Doğal ve artık riski mevcut kontrolleri dikkate alarak ayırın.
3. CSPM bulgusundaki veri türünü doğrulamak için ek kanıt isteyin.
4. Legacy sistem için risk kabulü ve telafi edici kontrol seçeneklerini tartışın.
5. Risk sahiplerini ve izleme göstergelerini önerin.
6. En önemli beş riski gerekçeli biçimde sıralayın.
7. Yönetime kısa bir risk iştahı tartışma notu hazırlayın.

5. TESLİM EDİLMESİ BEKLENEN ÇIKTI

- En az 5 satırlık risk register
- Doğal/artık risk dereceleri
- Kontrol ve kanıt boşlukları
- Önerilen KRI'lar
- Yönetici risk özeti

ÇALIŞMANIZI TAMAMLADINIZ MI?

Bu vaka çalışmasının tek bir doğru cevabı olmayabilir. Önemli olan; riskleri nasıl değerlendirdiğiniz, kanıtları nasıl yorumladığınız ve vardığınız sonucu nasıl savunduğunuzdur.

Çalışmanızı tamamladıktan sonra çıktınızı:

volkan@grcustasi.com

adresine gönderebilirsiniz.

Gönderdiğiniz çalışmayı inceleyerek size geri dönüş sağlayacağım.

- Volkan Güler, CISA, CISM
GRC Ustası